

Task 2 — Network Security & Scanning

Cybersecurity & Ethical Hacking Internship | ApexPlanet Software Pvt. Ltd.

Intern	Mayur Sangave
Task	Task 2 — Network Security & Scanning
Duration	Days 13–24
Date	2026-06-07
Status	Completed

1. Objective

The objective of Task 2 is to learn and practice reconnaissance, network scanning, vulnerability assessment, packet analysis, and firewall configuration. Using tools such as Nmap, OpenVAS, Wireshark, hping3, and iptables on a controlled lab environment consisting of Kali Linux (attacker) and Metasploitable2 (target).

2. Lab Environment

Component	Details	Status
Attacker Machine	Kali Linux (VirtualBox)	Active
Target Machine	Metasploitable2 (.vmdk)	Running
Network Type	Host-Only Adapter (192.168.56.0/24)	Configured
Kali IP	192.168.56.100	Active
Metasploitable2 IP	192.168.56.101	Active

3. Reconnaissance

3.1 Passive Recon — Whois & Nslookup

Passive reconnaissance gathers information about a target without directly interacting with it. Whois lookups reveal domain ownership details. Nslookup resolves domain names to IP addresses.

```
whois scanme.nmap.org
nslookup scanme.nmap.org
host scanme.nmap.org
```

Tool	Target	Finding
Whois	scanme.nmap.org	Registrar: ARIN Owner: Nmap Project Created: 2012
Nslookup	scanme.nmap.org	IP Address: 45.33.32.156

Host	scanme.nmap.org	IPv4: 45.33.32.156 IPv6: 2600:3c01::f03c:91ff:fe18:bb2f
------	-----------------	---

3.2 Active Recon — Ping Sweep

A ping sweep discovers all live hosts on the lab network by sending ICMP echo requests to every possible address in the subnet.

```
nmap -sn 192.168.56.0/24
```

IP Address	Host	Status
192.168.56.1	VirtualBox Gateway	Up
192.168.56.100	Kali Linux (Attacker)	Up
192.168.56.101	Metasploitable2 (Target)	Up

3.3 Banner Grabbing

Banner grabbing connects to a service port and reads the greeting message (banner) that reveals software name and version. This is critical for identifying vulnerable software versions.

```
nc -nv 192.168.56.101 21 # FTP
nc -nv 192.168.56.101 22 # SSH
nc -nv 192.168.56.101 80 # HTTP
```

Port	Service	Banner Received	Risk
21	FTP	220 (vsFTPd 2.3.4)	CRITICAL
22	SSH	SSH-2.0-OpenSSH_4.7p1 Debian	Medium
80	HTTP	Apache/2.2.8 (Ubuntu)	High

4. Port & Service Scanning

4.1 TCP SYN Scan

A SYN scan (also called a stealth scan) sends TCP SYN packets to ports and analyzes the response. Open ports reply with SYN-ACK. It is faster and less detectable than a full TCP connect scan.

```
sudo nmap -sS 192.168.56.101
```

4.2 Service Version Detection

```
sudo nmap -sV 192.168.56.101
sudo nmap -O 192.168.56.101
sudo nmap -A -oN task2_scan.txt 192.168.56.101
```

4.3 Full Nmap Scan Results on Metasploitable2

Port	Protocol	Service	Version	Risk Level
------	----------	---------	---------	------------

21	TCP	FTP	vsftpd 2.3.4	CRITICAL
22	TCP	SSH	OpenSSH 4.7p1	Medium
23	TCP	Telnet	Linux telnetd	High
25	TCP	SMTP	Postfix smtpd	Medium
53	TCP	DNS	ISC BIND 9.4.2	Medium
80	TCP	HTTP	Apache httpd 2.2.8	High
139/445	TCP	SMB	Samba 3.x	CRITICAL
3306	TCP	MySQL	MySQL 5.0.51a	High
5432	TCP	PostgreSQL	PostgreSQL 8.3	Medium
5900	TCP	VNC	VNC protocol 3.3	High
6000	TCP	X11	Access Allowed	High
8180	TCP	HTTP	Apache Tomcat	High

4.4 OS Detection Result

Nmap OS detection identified the target as running **Linux 2.6.9 - 2.6.33** based on TCP/IP stack fingerprinting. This confirms Metasploitable2 is a Linux-based system.

5. Vulnerability Scanning — OpenVAS

OpenVAS (Greenbone Vulnerability Manager) was used to perform a comprehensive vulnerability scan against Metasploitable2. The scanner checks the target against 80,000+ known CVEs and produces a detailed risk report.

5.1 OpenVAS Setup

```
sudo apt install openvas -y
sudo gvm-setup # Takes 15-20 mins – downloads vulnerability DB
sudo gvm-start # Start OpenVAS
# Access UI: https://127.0.0.1:9392
```

5.2 Scan Configuration

Setting	Value
Target Name	Metasploitable2
Target IP	192.168.56.101
Scan Config	Full and Fast
Scanner	OpenVAS Default
Scan Duration	~30 minutes

5.3 Top Critical Vulnerabilities Found

CVE / Vulnerability	Service	Port	Severity	Score
---------------------	---------	------	----------	-------

vsftpd 2.3.4 Backdoor Command Execution	FTP	21	CRITICAL	10.0
Samba MS-RPC Shell Command Injection	SMB	445	CRITICAL	9.3
UnrealIRCd Backdoor Detection	IRC	6667	CRITICAL	9.3
Distributed Ruby (dRuby) Remote Code Exec	dRuby	8787	CRITICAL	9.0
Apache Tomcat Default Files	HTTP	8180	High	7.5
MySQL Passwordless Root Access	MySQL	3306	High	7.5
VNC Server Weak Authentication	VNC	5900	High	7.2
Telnet Unencrypted Communication	Telnet	23	Medium	5.0
OpenSSH 4.7p1 Multiple Vulnerabilities	SSH	22	Medium	4.3

5.4 Vulnerability Summary

Severity	Count	Description
Critical	4	Remote code execution — immediate exploitation possible
High	8	Significant vulnerabilities requiring urgent attention
Medium	12	Moderate risk — should be patched
Low	6	Minor issues — low exploitation risk

6. Packet Analysis with Wireshark

6.1 FTP Traffic — Credential Capture

FTP transmits usernames and passwords as plain text with no encryption. By capturing FTP traffic in Wireshark and following the TCP stream, credentials were visible in clear text — demonstrating a critical security weakness of the FTP protocol.

```
# Step 1: Start Wireshark capture on eth0/eth1
# Step 2: Connect to FTP from terminal:
ftp 192.168.56.101
# Step 3: In Wireshark filter: ftp
# Step 4: Right-click packet -> Follow -> TCP Stream
# Result: USER msfadmin and PASS msfadmin visible in plaintext!
```

Protocol	Encrypted?	Credentials Captured	Finding
FTP (port 21)	No	Yes — plaintext	USER msfadmin PASS msfadmin
HTTP (port 80)	No	Yes — plaintext	Full page content readable
DNS (port 53)	No	Yes — plaintext	All domain lookups visible
SSH (port 22)	Yes	No — encrypted	Traffic unreadable (secure)

6.2 SYN Flood Attack Simulation

A SYN flood attack was simulated using hping3 to demonstrate how a DDoS attack overwhelms a target with connection requests. The flood was visible in Wireshark as hundreds of SYN packets per second.

```
sudo apt install hping3 -y
sudo hping3 -S --flood -V 192.168.56.101
# Press Ctrl+C after 3-4 seconds!
# Wireshark filter: tcp.flags.syn==1
```

Observation: Wireshark showed thousands of SYN packets per second with no corresponding ACK replies — a clear signature of a SYN flood DDoS attack.

7. Firewall Basics — iptables

iptables is the built-in Linux firewall. Rules were created to demonstrate allowing specific traffic and blocking port scan attempts. The effectiveness of each rule was verified using a before-and-after Nmap scan comparison.

7.1 Firewall Rules Created

```
sudo iptables -L # View current rules
sudo iptables -A INPUT -p tcp --dport 80 -j ACCEPT # Allow HTTP
sudo iptables -A INPUT -p tcp --dport 23 -j DROP # Block Telnet
sudo iptables -A INPUT -p tcp --tcp-flags ALL SYN -j DROP# Block port scans
sudo iptables -L -v # Verify rules
sudo iptables -F # Flush/clear rules
```

7.2 Rule Summary

Rule	Protocol	Port	Action	Purpose
Rule 1	TCP	80	ACCEPT	Allow legitimate web traffic
Rule 2	TCP	23	DROP	Block insecure Telnet
Rule 3	TCP	ALL	DROP SYN	Block port scanning attempts

7.3 Before vs After Port Scan Comparison

Scan	Port 21	Port 23	Port 80	Result
Before iptables rule	open	open	open	All ports visible to attacker
After iptables rule	filtered	filtered	filtered	Ports hidden — scan blocked!

8. Tools Used

Tool	Purpose	Commands Used	Status
Nmap	Network scanning & port discovery	-sS, -sV, -O, -A, -sn, -sU	Used
Netcat (nc)	Banner grabbing & connections	-nv	Used

OpenVAS/GVM	Vulnerability scanning	gvm-setup, gvm-start	Used
Wireshark	Packet capture & analysis	Filters: ftp, http, dns, tcp.flags	Used
hping3	SYN flood simulation	-S --flood -V	Used
iptables	Firewall rule creation	-A, -L, -F, -j ACCEPT/DROP	Used
Whois	Passive recon — domain info	whois	Used
Nslookup	DNS resolution lookup	nslookup	Used

9. Key Security Findings

- **vsftpd 2.3.4 Backdoor (CRITICAL)** — Port 21 FTP service contains a hidden backdoor that allows unauthenticated remote code execution. CVE-2011-2523.
- **Samba MS-RPC Injection (CRITICAL)** — Samba 3.x on ports 139/445 vulnerable to remote shell injection. CVE-2007-2447.
- **FTP Plaintext Credentials (CRITICAL)** — FTP transmits passwords with no encryption. Captured live using Wireshark.
- **MySQL No Root Password (High)** — MySQL 5.0.51a accessible with no password on root account.
- **Old SSH Version (Medium)** — OpenSSH 4.7p1 has multiple known vulnerabilities and should be upgraded.
- **Telnet Enabled (High)** — Telnet on port 23 transmits all data in plaintext — should be disabled.

10. Deliverables Completed

Deliverable	Status	Details
Nmap Scan Report (task2_scan.txt)	Done	Full -A scan saved to file
OpenVAS Vulnerability Report	Done	PDF exported from OpenVAS dashboard
GitHub Repository	Done	Notes, scan file, screenshots uploaded
5-min Demo Video	Done	Screen recording showing scan and findings
Wireshark Capture	Done	FTP plaintext capture + SYN flood demo
iptables Rules Demo	Done	Before and after screenshots documented

11. Conclusion

Task 2 has been successfully completed. A full network security assessment was performed on the Metasploitable2 target using industry-standard tools. Reconnaissance techniques (Whois, Nslookup, ping sweep, banner grabbing) were used to gather target information. Nmap scans revealed 20+ open ports with multiple critical vulnerabilities. OpenVAS identified 30+ CVEs including two critical remote code execution vulnerabilities (vsftpd backdoor and Samba injection). Wireshark demonstrated that FTP transmits credentials in plaintext. A SYN flood attack was simulated and observed. iptables firewall rules were configured and verified. The lab is now ready for Task 3: Web Application Security.